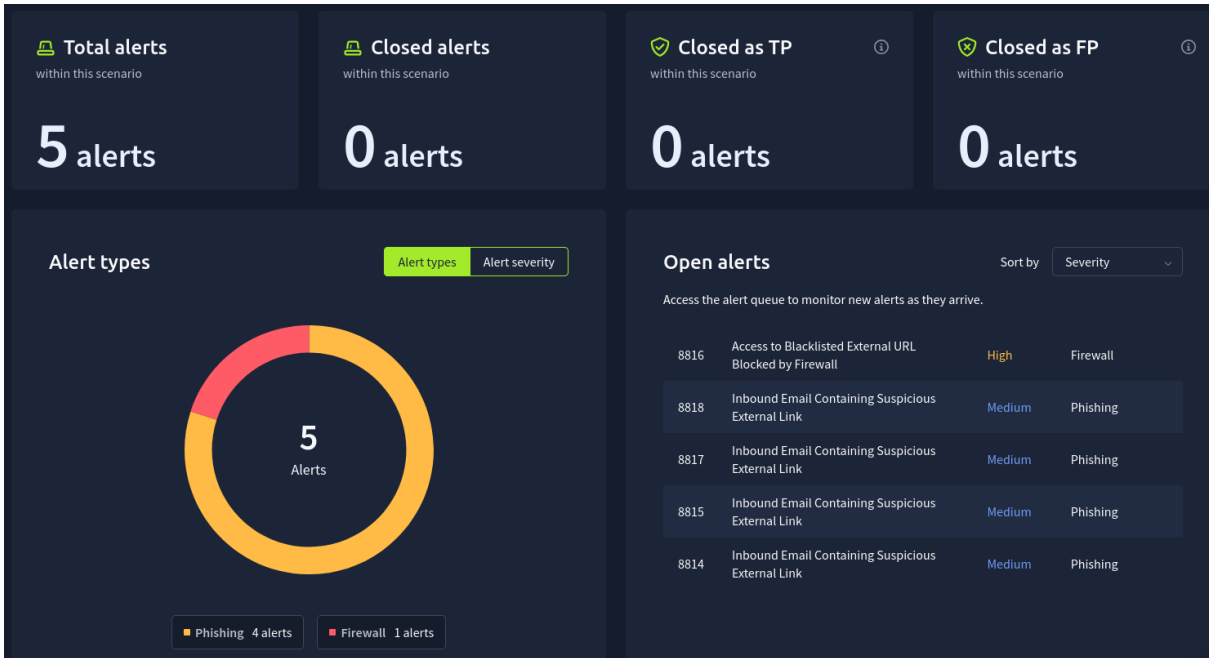


Usando SIEM (Splunk) na prática

Nesse cenário sou um analista SOC L1 reponsável em monitorar e analisar alertas em tempo real no SIEM (Splunk), correlacionar dados e classificar como True Positive (TP) ou False Positive (FP), decidir se escalo ou não, e escrever relatório.



Alerta 1

Na fila de alertas, decidi analisar por severidade (High):
8816 - Access to Blacklisted External URL Blocked by Firewall - High - Firewall

Dashboard

Alert queue

SIEM

Analyst VM

Documentation

Playbooks

Case reports

Guide

Q

Search for an alert

Reset filters

Severity

Status

Alert type

Show

15

alerts

ID	Alert rule	Severity	Type	Date	Status	Action
8818	Inbound Email Containing Suspicious External Link	Medium	Phishing	May 1st 2026 at 20:00	Awaiting action	
8817	Inbound Email Containing Suspicious External Link	Medium	Phishing	May 1st 2026 at 20:00	Awaiting action	
8816	Access to Blacklisted External URL Blocked by Firewall	High	Firewall	May 1st 2026 at 19:59	Awaiting action	

Description:

datasource:

timestamp:

Action:

SourceIP:

SourcePort:

DestinationIP:

DestinationPort:

URL:

Application:

Protocol:

Rule:

This alert was triggered when a user attempted to access an external URL that is listed in the organization's blacklist or threat intelligence feeds. The firewall or proxy successfully blocked the outbound request, preventing the connection. Note: The blacklist only covers known threats. It does not guarantee protection against new or unknown malicious domains.

firewall

05/01/2026 19:57:18.087

blocked

10.20.2.17

34257

67.199.248.11

80

http://bit.ly/3sHkX3da12340

web-browsing

TCP

Blocked Websites

Descrição:

Este alerta foi acionado quando um usuário tentou acessar um URL externo que consta na lista negra da organização ou nos feeds de inteligência de ameaças. O firewall ou proxy bloqueou com sucesso a solicitação de saída, impedindo a conexão. Observação: a lista negra abrange apenas ameaças conhecidas. Ela não garante proteção contra domínios maliciosos novos ou desconhecidos.

datasource: firewall

timestamp: 05/02/2026 13:00:10.865

Action: blocked

SourceIP: 10.20.2.17

SourcePort: 34257

DestinationIP: 67.199.248.11

DestinationPort: 80

URL: <http://bit.ly/3sHkX3da12340>

Application: web-browsing

Protocol: TCP

Rule: Blocked Websites

RESUMO DO ALERTA

- **IP interno:** 10.20.2.17
- **Usuário (pela tabela):** Hannah Harris (RH)
- **Destino:** 67.199.248.11
- **URL:** bit.ly (encurtador)
- **Ação:** blocked ✓
- **Regra:** Blocked Websites
- **Severidade:** High

ANÁLISE REAL

O que aconteceu:

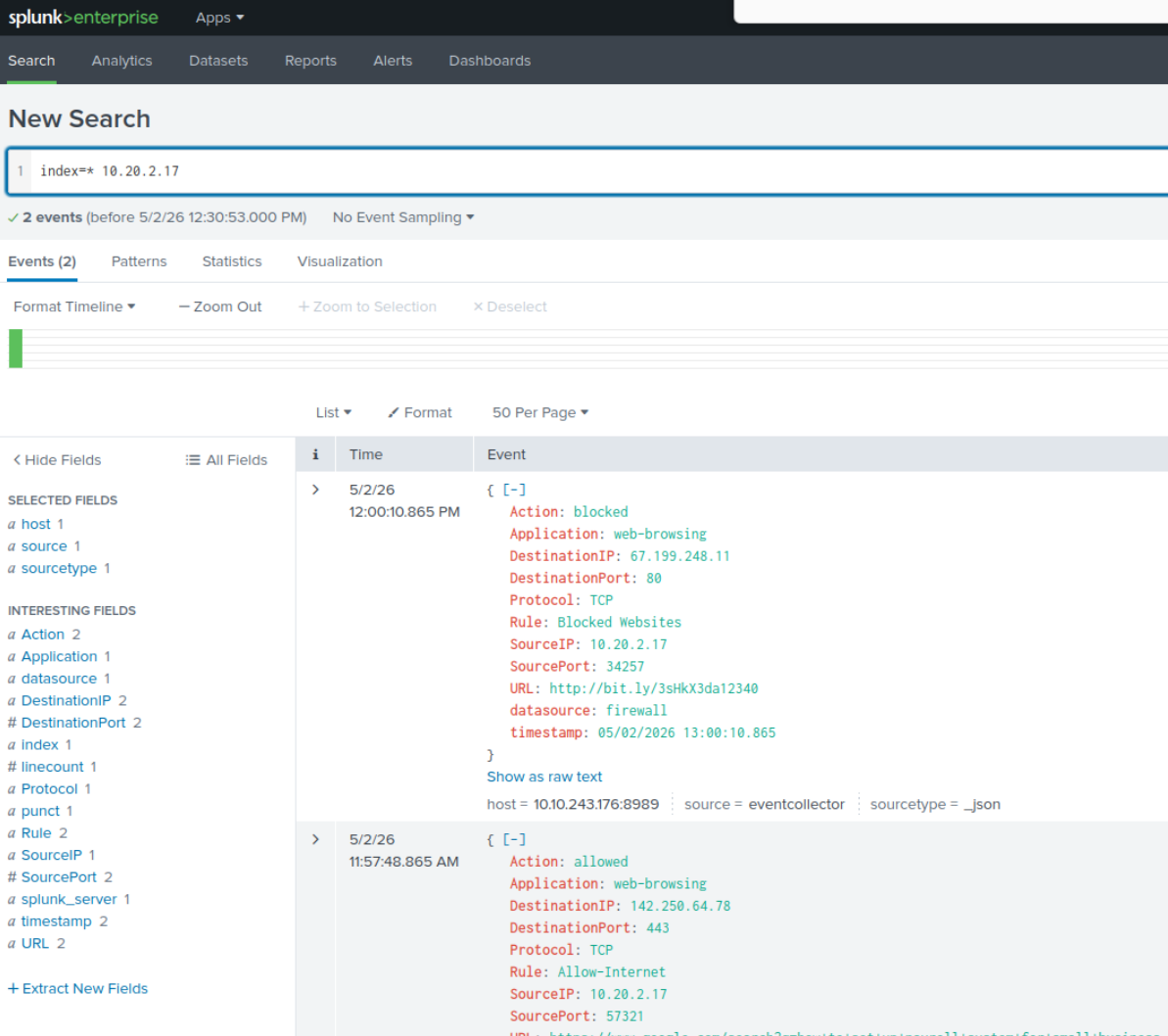
- Usuário tentou acessar um link encurtado (bit.ly)
- Esse tipo de link é MUITO usado em phishing

- O firewall reconheceu como suspeito
- **Bloqueou antes de qualquer conexão acontecer**

O alerta é apenas o ponto de partida. Eu sempre valido no SIEM para obter contexto adicional, como frequência, origem e impacto da atividade. Por isso vamos analisar algumas coisas no SIEM (Splunk):

1- Analisar se houve mais tentativas:

index=* 10.20.2.17



The screenshot shows the Splunk Enterprise interface. At the top, there's a navigation bar with 'Search', 'Analytics', 'Datasets', 'Reports', 'Alerts', and 'Dashboards'. Below this is a 'New Search' section with a search bar containing 'index=* 10.20.2.17'. Below the search bar, it says '2 events (before 5/2/26 12:30:53.000 PM) No Event Sampling'. Below this is a table with two columns: 'Time' and 'Event'. The first event is at 5/2/26 12:00:10.865 PM, with Action: blocked, Application: web-browsing, DestinationIP: 67.199.248.11, DestinationPort: 80, Protocol: TCP, Rule: Blocked Websites, SourceIP: 10.20.2.17, SourcePort: 34257, URL: http://bit.ly/3sHkX3da12340, and datasource: firewall. The second event is at 5/2/26 11:57:48.865 AM, with Action: allowed, Application: web-browsing, DestinationIP: 142.250.64.78, DestinationPort: 443, Protocol: TCP, Rule: Allow-Internet, SourceIP: 10.20.2.17, SourcePort: 57321, and URL: https://www.google.com/search?q=how+to+set+up+payroll+system+for+small+business. On the left side, there's a sidebar with 'SELECTED FIELDS' (host 1, source 1, sourcetype 1) and 'INTERESTING FIELDS' (Action 2, Application 1, datasource 1, DestinationIP 2, DestinationPort 2, index 1, linecount 1, Protocol 1, punct 1, Rule 2, SourceIP 1, SourcePort 2, splunk_server 1, timestamp 2, URL 2). At the bottom of the sidebar, there's a link '+ Extract New Fields'.

i	Time	Event
>	5/2/26 12:00:10.865 PM	{ [-] Action: blocked Application: web-browsing DestinationIP: 67.199.248.11 DestinationPort: 80 Protocol: TCP Rule: Blocked Websites SourceIP: 10.20.2.17 SourcePort: 34257 URL: http://bit.ly/3sHkX3da12340 datasource: firewall timestamp: 05/02/2026 13:00:10.865 } Show as raw text host = 10.10.243.176:8989 source = eventcollector sourcetype = _json
>	5/2/26 11:57:48.865 AM	{ [-] Action: allowed Application: web-browsing DestinationIP: 142.250.64.78 DestinationPort: 443 Protocol: TCP Rule: Allow-Internet SourceIP: 10.20.2.17 SourcePort: 57321 URL: https://www.google.com/search?q=how+to+set+up+payroll+system+for+small+business

2 - Analisar se alguém conseguiu acessar (allowed)

index=* "67.199.248.11"

i	Time	Event
>	5/2/26 12:00:10.865 PM	<pre>{ [-] Action: blocked Application: web-browsing DestinationIP: 67.199.248.11 DestinationPort: 80 Protocol: TCP Rule: Blocked Websites SourceIP: 10.20.2.17 SourcePort: 34257 URL: http://bit.ly/3sHkX3da12340 datasource: firewall timestamp: 05/02/2026 13:00:10.865 }</pre> Show as raw text host = 10.10.243.176:8989 source = eventcollector sourcetype = _json
>	5/2/26 11:57:48.865 AM	<pre>{ [-] Action: allowed Application: web-browsing DestinationIP: 142.250.64.78 DestinationPort: 443 Protocol: TCP Rule: Allow-Internet SourceIP: 10.20.2.17 SourcePort: 57321 URL: https://www.google.com/search?q=how+to+set+up+payroll+system+for+small+business datasource: firewall timestamp: 05/02/2026 12:57:48.865 }</pre> Show as raw text host = 10.10.243.176:8989 source = eventcollector sourcetype = _json

3. Analisar origem (email phishing?)

index=* "bit.ly"

i	Time	Event
>	5/2/26 12:00:10.865 PM	<pre>{ [-] Action: blocked Application: web-browsing DestinationIP: 67.199.248.11 DestinationPort: 80 Protocol: TCP Rule: Blocked Websites SourceIP: 10.20.2.17 SourcePort: 34257 URL: http://bit.ly/3sHkX3da12340 datasource: firewall timestamp: 05/02/2026 13:00:10.865 }</pre> Show as raw text host = 10.10.243.176:8989 source = eventcollector sourcetype = _json
>	5/2/26 11:58:56.865 AM	<pre>{ [-] attachment: None content: Dear Customer,\n\nWe were unable to deliver your package due to an incomplete address.\n\nPlease confirm your shipping information by clicking the link below:\n\nhttp://bit.ly/3sHkX3da12340\n\nIf we don't hear from you within 48 hours, your package will be returned to sender.\n\nThank you,\n\nAmazon Delivery datasource: email direction: inbound recipient: h.harris@thetrydaily.thm sender: urgents@amazon.biz subject: Your Amazon Package Couldn't Be Delivered - Action Required timestamp: 05/02/2026 12:58:56.865 }</pre> Show as raw text host = 10.10.243.176:8989 source = eventcollector sourcetype = _json

CLASSIFICAÇÃO CORRETA

NÃO é False Positive

Por quê?

- bit.ly é comum em campanhas maliciosas
- comportamento é potencialmente perigoso

CLASSIFICAÇÃO CERTA:

True Positive

Porque:

houve tentativa de acesso a recurso malicioso

ESCALONAMENTO

Escalar ou não?

Neste caso:

- ✓ Firewall bloqueou
- ✓ Nenhuma execução
- ✓ Nenhuma conexão estabelecida

DECISÃO:

True Positive — SEM escalonamento

RELATÓRIO FINAL

Horário da atividade:

05/01/2026 19:57:18

Lista de entidades afetadas:

- Usuário: Hannah Harris (h.harris@thetrydaily.thm)
- **IP de origem:** 10.20.2.17
- **Host:** win-3457
- **IP de destino:** 67.199.248.11
- **URL:** <http://bit.ly/3sHkX3da12340>

Motivo para classificação como verdadeiro positivo:

Esta atividade foi classificada como um verdadeiro positivo porque um usuário da rede interna tentou acessar uma URL externa listada como suspeita. A URL utiliza um serviço de encurtamento de URLs (bit.ly), comumente associado a campanhas de phishing e redirecionamentos maliciosos. O destino consta em feeds de inteligência de ameaças, confirmando sua natureza maliciosa.

Motivo para escalonamento do alerta:

O escalonamento não é necessário neste caso. Embora a atividade tenha envolvido uma URL maliciosa, o firewall bloqueou a solicitação com sucesso, impedindo qualquer conexão com o host externo. Nenhuma outra atividade suspeita ou sinal de comprometimento foi observado no sistema afetado.

Ações de remediação recomendadas:

- Instruir o usuário sobre os riscos de phishing e links suspeitos.
- Monitorar a atividade do usuário para identificar tentativas repetidas.
- Garantir que a proteção de endpoint esteja ativa e atualizada.
- Continuar monitorando blocos de firewall semelhantes em busca de padrões que indiquem campanhas de phishing.

Lista de indicadores de ataque:

- **IP de origem:** 10.20.2.17
- **IP de destino:** 67.199.248.11
- **URL:** <http://bit.ly/3sHkX3da12340>
- **Protocolo:** TCP
- **Porta de destino:** 80
- **Aplicativo:** navegação na web

Alerta 2

ANÁLISE RÁPIDA

O que temos:

- Email externo (**inbound**)
- Link para “onboarding”
- Pressão leve (“Action Required”)
- Link clicável
- Nenhum anexo

SINAIS DE ALERTA

Pontos suspeitos:

- Domínio **hrconnex.thm** (não sabemos se é confiável)
- Uso de link direto para ação
- Engenharia social (onboarding / acesso)
- Usuária real da empresa (Julia Garcia)

PERGUNTA PRINCIPAL (SOC)

Alguém clicou no link?

Isso define tudo:

- Não clicou → baixo risco
- Clicou → risco alto

NO SIEM

1. Procurar acesso ao domínio

index=* "hrconnex.thm"

i	Time	Event
>	5/1/26 7:00:26.623 PM	<pre>[-] attachment: None content: Hi Ms. Garcia,\n\nWelcome to TheTryDaily!\n\nAs part of your onboarding, please complete your final profile setup so we can configure your access.\n\nKindly click the link below:\n\nSet Up My Profile.\n\nIf you have questions, please reach out to the HR Onboarding Team. datasource: email direction: inbound recipient: j.garcia@thetrydaily.thm sender: onboarding@hrconnex.thm subject: Action Required: Finalize Your Onboarding Profile timestamp: 05/01/2026 20:00:26.623 }</pre> Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json
>	5/1/26 6:56:00.623 PM	<pre>[-] attachment: None content: Hi IT Team,\n\nHope you're doing well! I'm reaching out because one of our new hires, J. Garcia, hasn't received her onboarding email from hrconnex.thm, which is our new third-party HR partner for handling account setup and paperwork.\n\nHe was supposed to receive a link to complete her profile and sign some documents, but it hasn't come through - not in her inbox or spam. We've double-checked the email address on our end, and it's correct.\n\nLet me know if you need any more info from my side.\n\n datasource: email direction: internal recipient: j.carter@thetrydaily.thm sender: h.harris@thetrydaily.thm subject: Unable to Receive Onboarding Email from hrconnex.thm timestamp: 05/01/2026 19:56:00.623 }</pre> Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json
>	5/1/26 6:54:27.623 PM	<pre>[-] attachment: None content: Hi Ms. Garcia,\n\nWelcome to TheTryDaily!\n\nAs part of your onboarding, please complete your final profile setup so we can configure your access.\n\nKindly click the link below:\n\nSet Up My Profile.\n\nIf you have questions, please reach out to the HR Onboarding Team. datasource: email direction: inbound recipient: j.garcia@thetrydaily.thm sender: onboarding@hrconnex.thm subject: Action Required: Finalize Your Onboarding Profile timestamp: 05/01/2026 19:54:27.623 }</pre> Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json

Descoberta

1. Email interno ANTES do alerta

- Hannah Harris (RH) falou com TI
- Disse que:
- A nova funcionária **Julia Garcia** deveria receber email do hrconnex.thm

Isso valida o domínio!

2. Email recebido pela Julia

- Mesmo domínio: **hrconnex.thm**
- Mesmo contexto: onboarding
- Conteúdo coerente

NÃO parece ataque

CONCLUSÃO

Esse NÃO é phishing

✓ False Positive

The screenshot shows a security dashboard with a table of alerts. A modal is open for alert ID 8818, asking for classification. The modal has two options: 'True positive' and 'False positive', with 'False positive' selected. The background table shows several alerts with the same rule name, all with a status of 'Awaiting action'.

ID	Alert rule	Severity	Alert type	Date	Status	Action
8818	Inbound Email Containing Suspicious External Link	Medium	Phishing	May 1st 2026 at 20:00		
8817	Inbound Email Containing Suspicious External Link	Medium	Phishing	May 1st 2026 at 20:00	Awaiting action	
8815	Inbound Email Containing Suspicious External Link	Medium	Phishing	May 1st 2026 at 19:58	Awaiting action	
8814	Inbound Email Containing Suspicious External Link	Medium	Phishing	May 1st 2026 at 19:54	Awaiting action	

POR QUE?

- ✓ Domínio mencionado previamente por funcionário interno
- ✓ Contexto legítimo (onboarding de nova funcionária)
- ✓ Comunicação consistente
- ✓ Nenhum sinal de spoofing ou fraude

CLASSIFICAÇÃO FINAL

False Positive

Sem escalonamento

RELATÓRIO FINAL

Horário da atividade:

05/01/2026 19:54:27 – 20:00:26

Lista de entidades afetadas:

- Usuário: Julia Garcia (j.garcia@thetrydaily.thm)
- Remetente: onboarding@hrconnex.thm
- Usuário relacionado: Hannah Harris (h.harris@thetrydaily.thm)
- Host interno: win-3452 (10.20.2.8)

Motivo da classificação como falso positivo:

Esta atividade foi classificada como um falso positivo. Embora o e-mail inicialmente parecesse suspeito devido à presença de um link externo e características de engenharia social, uma investigação mais aprofundada revelou que o domínio hrconnex.thm é um serviço legítimo de RH de terceiros usado pela organização.

Um e-mail interno de Hannah Harris (departamento de RH) confirmou que Julia Garcia deveria receber um e-mail de integração deste domínio. O conteúdo, o momento e o contexto do e-mail são consistentes com procedimentos legítimos de integração. Não foram identificados indicadores de intenção maliciosa ou comprometimento.

Motivo para a Escalada do Alerta:

A escalção não é necessária. A atividade foi verificada como comunicação comercial legítima e nenhum comportamento suspeito ou malicioso foi detectado.

Ações de Remediação Recomendadas:

Revisar e ajustar as regras de detecção para reduzir falsos positivos semelhantes.

Adicionar o domínio hrconnex.thm à lista de permissões, se apropriado.

Continuar monitorando o uso anormal de domínios confiáveis.

Lista de Indicadores de Ataque:

- Remetente: onboarding@hrconnex.thm
- Destinatário: j.garcia@thetrydaily.thm
- URL: <https://hrconnex.thm/onboarding/15400654060/j.garcia>
- Assunto: Ação Necessária: Finalize seu Perfil de Integração

Alerta 3

Na descrição do alerta parece se tratar de um **phishing clássico e perigoso**

ANÁLISE RÁPIDA

O que temos:

- Domínio falso: **m1crosoftsupport.co** (com “1” no lugar de “i”)
- Tema urgente: “Unusual Sign-In Activity”
- Engenharia social (medo + urgência)
- Link para login
- IP e localização (Lagos) para dar credibilidade

RED FLAGS (muito fortes)

- Typosquatting (m1crosoft ≠ microsoft)
- Domínio externo desconhecido
- Pedido para clicar e logar
- Simulação de alerta de segurança

Isso é **credential harvesting (roubo de senha)**

CHECAR NO SPLUNK

Charlotte Allen clicou no link?

Buscar acesso ao domínio

index=* "[m1crosoftsupport.co](https://microsoftsupport.co)"

>	5/1/26 7:01:07.623 PM	{ [-] Action: allowed Application: web-browsing DestinationIP: 45.148.10.131 DestinationPort: 443 Protocol: TCP Rule: Allow-Internet SourceIP: 10.20.2.25 SourcePort: 32653 URL: https://microsoftsupport.co/login datasource: firewall timestamp: 05/01/2026 20:01:07.623 } Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json
>	5/1/26 6:59:58.623 PM	{ [-] attachment: None content: Hi C.Allen,\nWe detected an unusual sign-in attempt on your Microsoft account.\nLocation: Lagos, Nigeria\nIP Address: 102.89.222.143\nDate: 2025-01-24 06:42\nIf this was not you, please secure your account immediately to avoid unauthorized access.\nhref=https://microsoftsupport.co/login>Review Activity\nThank you,\nMicrosoft Account Security Team datasource: email direction: inbound recipient: c.allen@thetrydaily.thm sender: no-reply@microsoftsupport.co subject: Unusual Sign-In Activity on Your Microsoft Account timestamp: 05/01/2026 19:59:58.623 } Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json

Acabo de confirmar que o link foi acessado e isso virou um **incidente real de segurança**

O QUE ACONTECEU (linha do tempo)

19:59:58

- Email phishing recebido (m1crosoftsupport.co)

20:01:07

- Usuária **Charlotte Allen (10.20.2.25)**
- **ACESSOU** o link
- **Action: allowed**

CONCLUSÃO

O usuário **clicou no link malicioso**
A conexão foi **permitida pelo firewall**

CLASSIFICAÇÃO

True Positive (confirmado)

ESCALONAMENTO

SIM — ESCALATION REQUIRED

Por quê?

- Possível roubo de credenciais
- Usuário interagiu com phishing
- Acesso ao site malicioso foi permitido

Isso é exatamente o que SOC chama de:

User Compromise Risk

RELATÓRIO FINAL

Horário da atividade:

05/01/2026 19:59:58 – 20:01:07

Lista de entidades afetadas:

- Usuário: Charlotte Allen (c.allen@thetrydaily.thm)
- IP de origem: 10.20.2.25
- Host: win-3463
- IP de destino: 45.148.10.131
- Domínio malicioso: m1crosoftsupport.co

Motivo da classificação como verdadeiro positivo:

Esta atividade foi classificada como um verdadeiro positivo devido a um ataque de phishing confirmado. O e-mail originou-se de um domínio registrado por typosquatting (m1crosoftsupport.co), se passando pela Microsoft para enganar o usuário. O e-mail continha elementos de engenharia social, como urgência e avisos de segurança, para induzir o usuário a tomar alguma ação.

Investigações adicionais confirmaram que o destinatário acessou a URL maliciosa (<https://m1crosoftsupport.co/login>), estabelecendo uma conexão de saída bem-sucedida com o servidor externo (45.148.10.131). Isso indica que a tentativa de phishing progrediu além da entrega e houve interação com o usuário.

Motivo para a Escalada do Alerta:

A escalção é necessária, pois o usuário interagiu com o e-mail de phishing e acessou o site malicioso. Isso cria um alto risco de comprometimento de credenciais e potencial acesso não autorizado aos sistemas corporativos. Ações de resposta imediatas são necessárias para conter e mitigar a ameaça.

Ações de correção recomendadas:

- Forçar a redefinição de senha para o usuário afetado
- Invalidar sessões e tokens ativos
- Monitorar atividades de login suspeitas
- Realizar varredura de endpoint no host afetado
- Bloquear o domínio e o IP maliciosos no firewall
- Realizar treinamento de conscientização sobre phishing para o usuário

Lista de indicadores de ataque:

- Remetente: no-reply@m1crosoftsupport.co
- Destinatário: c.allen@thetrydaily.thm
- IP de origem: 10.20.2.25
- IP de destino: 45.148.10.131
- URL: <https://m1crosoftsupport.co/login>
- Protocolo: TCP
- Porta: 443

O QUE FOI FEITO

- ✓ correlacionei email + firewall
- ✓ identifiquei clique real
- ✓ detectei risco de comprometimento
- ✓ decidi escalar corretamente

Alerta 4

Alerta muito parecido com o **segundo alerta**, mas preciso provar isso como analista.

Nunca assumir — Sempre validar (isso é mentalidade SOC).

ANÁLISE INICIAL

Mesmo padrão:

- Sender: onboarding@hrconnex.thm
- Mesmo link
- Mesmo contexto (onboarding)
- Mesma usuária: Julia Garcia

PASSO CRÍTICO

Já vi antes que:

hrconnex.thm é legítimo

Porque:

- RH mencionou antes
- Faz parte do onboarding real

MAS COMO ANALISTA DEVO CONFIRMAR

No Splunk, fez isso antes:

```
index=* "hrconnex.thm"
```

E encontrei:

- ✓ Email interno validando
- ✓ Fluxo legítimo

CONCLUSÃO

Esse alerta é apenas outra ocorrência do mesmo evento legítimo

CLASSIFICAÇÃO

False Positive

ESCALONAMENTO

NÃO escalar

RACIOCÍNIO PROFISSIONAL

Não estou analisando só o alerta estou vendo o **contexto do ambiente**

Mesmo domínio + mesmo contexto + já validado

"Recurring alert associated with previously validated legitimate activity."

RELATÓRIO FINAL

Horário da atividade:

05/01/2026 19:52:51

Lista de entidades afetadas:

- Usuário: Julia Garcia (j.garcia@thetrydaily.thm)
- Remetente: onboarding@hrconnex.thm
- Host: win-3452 (10.20.2.8)

Motivo da classificação como falso positivo:

Esta atividade foi classificada como um falso positivo. O e-mail contém um link externo e inicialmente levantou suspeitas; no entanto, uma investigação mais aprofundada confirmou que o domínio hrconnex.thm é um serviço legítimo de RH de terceiros utilizado pela organização.

Comunicação interna anterior do departamento de RH confirmou que o usuário deveria receber instruções de integração deste domínio. O conteúdo e o momento do e-mail são consistentes com procedimentos legítimos de integração e nenhuma intenção maliciosa foi identificada.

Motivo para a escalada do alerta:

A escalada não é necessária. A atividade foi verificada como comunicação comercial legítima, sem sinais de comprometimento ou comportamento malicioso.

Ações de correção recomendadas:

- Ajuste as regras de detecção para reduzir falsos positivos semelhantes.
- Considere adicionar hrconnex.thm à lista de permissões, se apropriado.
- Continue monitorando o uso indevido de domínios confiáveis.

Lista de indicadores de ataque:

- Remetente: onboarding@hrconnex.thm
- Destinatário: j.garcia@thetrydaily.thm
- URL: <https://hrconnex.thm/onboarding/15400654060/j.garcia>
- Assunto: Ação necessária: Finalize seu perfil de integração

Alerta 5

Lendo o alerta percebo que é um **phishing clássico de engenharia social**

ANÁLISE RÁPIDA

O que temos:

- Sender: **urgents@amazon.biz** (não é domínio oficial)
- Tema: entrega (muito comum em phishing)
- Urgência: "48 hours"
- Link encurtado: **bit.ly**
- Usuária: Hannah Harris (RH)

RED FLAGS

- Domínio falso (amazon.biz ≠ amazon.com)
- Uso de encurtador (bit.ly)
- Pressão psicológica
- Pedido de ação imediata

Isso é **phishing claro**

AGORA O MAIS IMPORTANTE

Esse link é o MESMO do primeiro alerta:

<http://bit.ly/3sHkX3da12340>

✓ Foi **bloqueado pelo firewall**

CORRELAÇÃO

Conectei:

- Email phishing
- Tentativa de acesso
- Firewall bloqueou

Isso fecha o ciclo completo

CLASSIFICAÇÃO

True Positive

ESCALONAMENTO

NÃO escalar

Por quê?

- Acesso foi bloqueado
- Sem execução
- Sem impacto

RELATÓRIO FINAL

Horário da atividade:

05/01/2026 19:56:04

Lista de entidades afetadas:

- Usuário: Hannah Harris (h.harris@thetrydaily.thm)
- IP de origem: 10.20.2.17
- Host: win-3457
- Remetente: urgents@amazon.biz
- IP de destino: 67.199.248.11
- URL: <http://bit.ly/3sHkX3da12340>

Motivo da classificação como verdadeiro positivo:

Esta atividade foi classificada como um verdadeiro positivo devido a um e-mail de phishing se passando pela Amazon. O domínio do remetente (amazon.biz) não está associado ao domínio legítimo da Amazon e provavelmente é malicioso. O e-mail utiliza técnicas de engenharia social, como urgência e falha na entrega, para enganar o usuário e levá-lo a clicar em um link malicioso.

A URL incorporada é um link encurtado (bit.ly), comumente usado para ocultar destinos maliciosos. Investigações anteriores confirmaram que este URL está associado a um destino em lista negra.

Motivo para a Escalada do Alerta:

A escalção não é necessária. Embora a tentativa de phishing tenha sido confirmada, o firewall bloqueou com sucesso a solicitação de saída para o URL malicioso, impedindo qualquer conexão ou possível comprometimento. Nenhuma outra atividade suspeita foi observada.

Ações de Remediação Recomendadas:

- Educar o usuário sobre e-mails de phishing e links suspeitos
- Bloquear domínios e URLs semelhantes no nível do firewall
- Monitorar tentativas repetidas de phishing direcionadas a funcionários
- Aprimorar as políticas de filtragem de e-mail

Lista de Indicadores de Ataque:

- Remetente: urgents@amazon.biz
- Destinatário: h.harris@thetrydaily.thm
- URL: <http://bit.ly/3sHkX3da12340>
- IP de Destino: 67.199.248.11
- Protocolo: TCP
- Porta: 80

Conclusão

Concluí com sucesso o ciclo completo de análise em um ambiente de Security Operations Center (SOC), aplicando uma abordagem estruturada e orientada a evidências. Durante o processo, realizei a investigação de alertas, correlacionei múltiplas fontes de dados (email e firewall), identifiquei atividades maliciosas reais, incluindo campanhas de phishing, e diferenciei com precisão entre falsos positivos e verdadeiros positivos.

Além disso, tomei decisões fundamentadas sobre a necessidade de escalonamento com base no impacto e risco identificado, e elaborei relatórios técnicos claros e detalhados, alinhados às boas práticas de resposta a incidentes.

Esse processo demonstra capacidade prática em análise de segurança, pensamento crítico e atuação alinhada aos fluxos operacionais de um SOC.

Sobre o autor



Paulo Cesar é formado em Segurança da informação pela Universidade Nove de Julho e apaixonado por Cibersegurança! Mais informações e contato:

linkedin.com/in/paulo-cesar-security